



美好生活 共享安全

饿了么第一届信息安全峰会

云时代的安全架构设计

李滨



🍁 架构之道

- 架构之禅
- 架构之法
- 架构之术
- 架构之器
- 架构之困
- 架构之行



架构之道

所谓架构：一门用于设计和监督建筑构建过程的科学和艺术

archi+tec+ture n. 1. the art and science of designing and supervising the construction of buildings and similar structures. 2. a style of building or structure: Gothic architecture. 3. buildings or structures collectively. 4. the structure or design of anything: *the architecture of the universe*. **archi+tec+tural** adj.

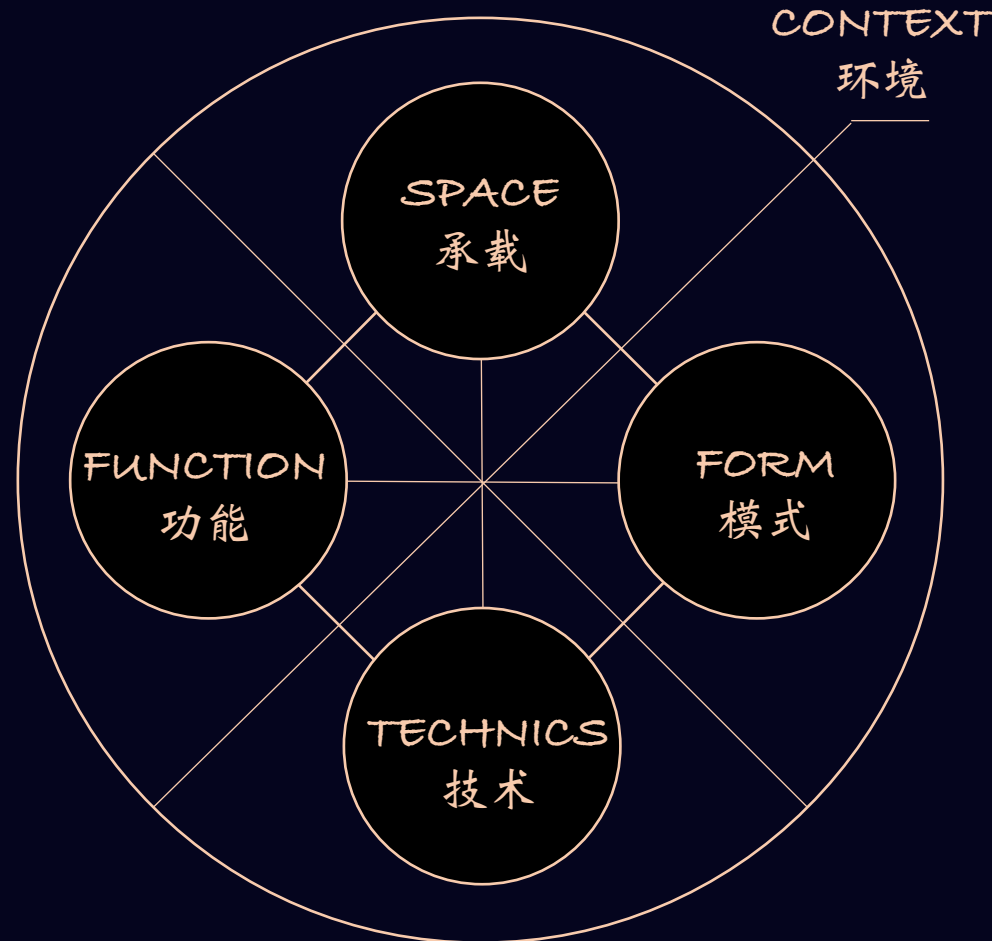
所谓安全：防患于未然，救患于危难，止患于前行

se+cure adj. 1. free from danger, damage, etc. 2. free from fear, care, etc. 3. in safe custody. 4. not likely to fail, become loose, etc. 5. able to be relied on: certain: a secure investment.

所谓系统：由若干要素以一定结构形式联结构成的具有某种功能的有机整体。在这个定义中包括了系统、要素、结构、功能四个概念。

系统五要素：整体性，结构性，关联性，动态平衡性，时序性

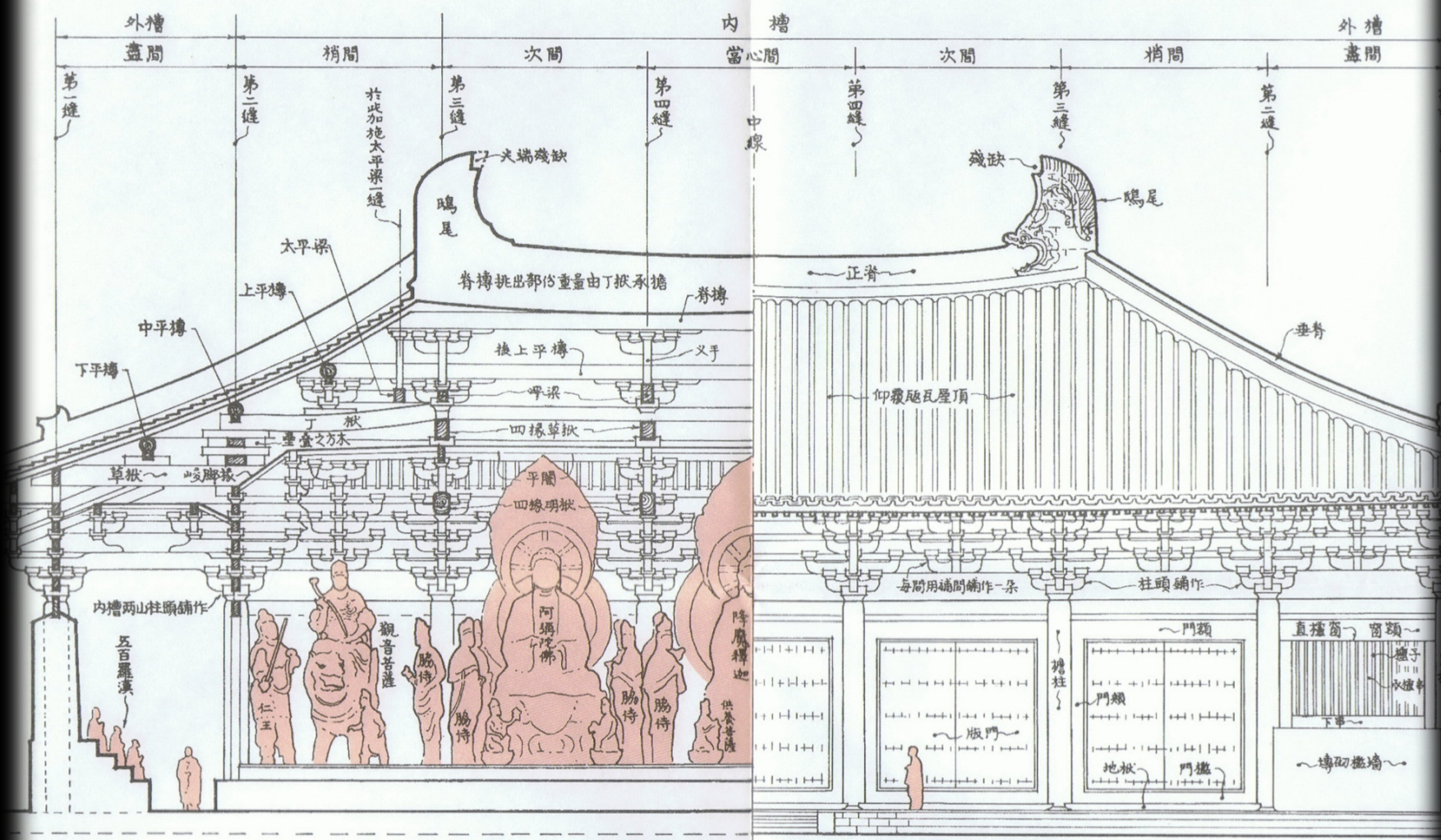
系统工程：通过系统解析的方法，分析要素与要素、要素与系统、系统与环境等方面的关系，优化解决问题。



不忘初心，方得始终

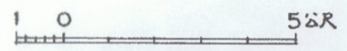
架构之禅

- 视角与层级
 - 系统五要素：整体性，结构性，关联性，平衡性，时序性(生命周期)
 - 业务视图(Conceptual Level): 定义外部环境，业务流程，企业标准
 - 逻辑视图(Logical Level): 系统组件逻辑关系
 - 物理视图(Physical Level): 部署和物理视图
 - 逻辑架构：不同数据域或功能域之间的关联关系
 - 组件模型：概括的描述系统内组件的堆叠或联系
 - 数据流图(DFD): 系统内数据的流向、交互关系和处理方式
- 

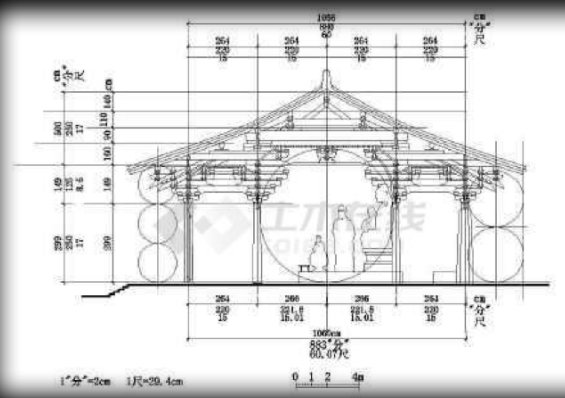
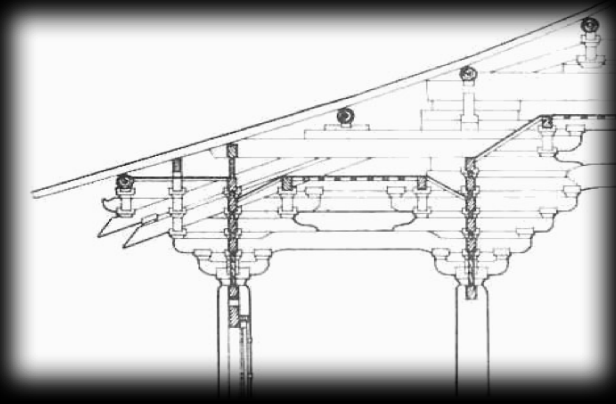
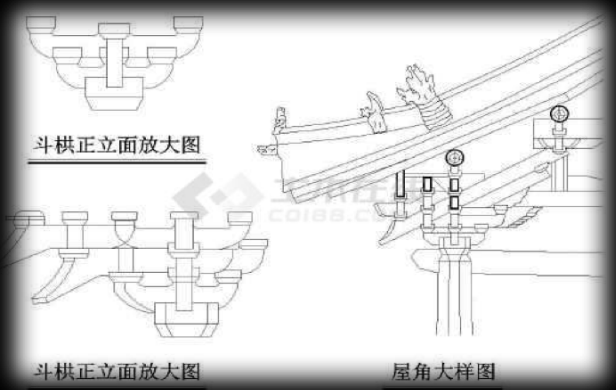


LONGITUDINAL SECTION 縱斷面

西立面 WEST ELEVATION



山西五台山 佛光寺大殿 唐大中十一年建 857 A.D.



架构之法

- *Apply defense in depth.* 纵深防御
 - *Defense in multiple places* 机制互补
 - *Layered defense* 多层防护
 - *Use a positive security model (fail-safe defaults, minimize attack surface). Fail securely.* 最小攻击面
 - *Run with least privilege.* 最小特权
 - *Avoid security by obscurity (open design).* 开放设计
 - *Keep security simple (verifiable, economy of mechanism).* 保持简单
 - *Detect intrusions (compromise recording).* 主动检测
 - *Don't trust infrastructure.* 别信任基础设施
 - *Don't trust services.* 别信任其他服务
 - *Establish secure defaults.* 构建缺省安全策略
 - *Difference problem and solution.* 分清问题和措施
- 

架构之术



架构之器

能力和
成熟度量

BSIMM
SAMM

安全
开发流程

SDLC

需求架构 威胁分析 风险评估 风险消减

DFD
Decompose
Business Analysis

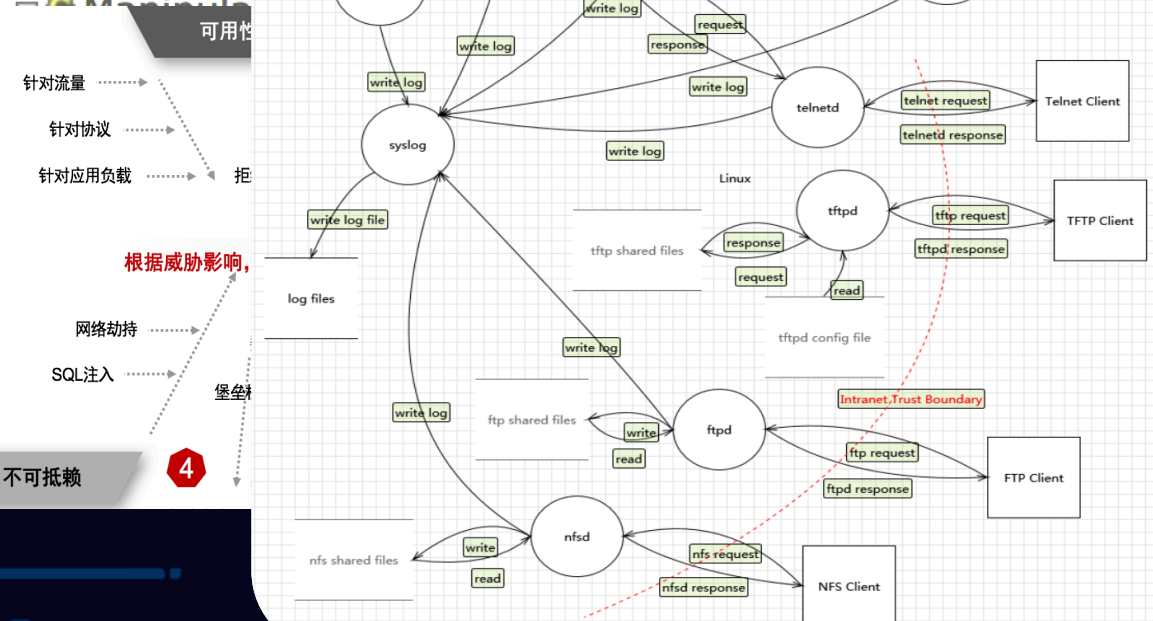
STRIDE
FTA / FMEA
CAPEC / CWE
Security Pattern

FMEA
AVT
CVSS

CVE
Mitigation Case
Coding Standard

1000 - Mechanisms of Attack

- + Collect and Analyze Information - (118)
- + Inject Untrusted Data - (153)
- + Engage in Denial of Service - (153)
- + Manipulate Data - (153)
- + Abuse Existing Privileges - (153)
- + Employ Social Engineering - (153)
- + Subvert the System - (153)
- + Manipulate the System - (153)



架构之困

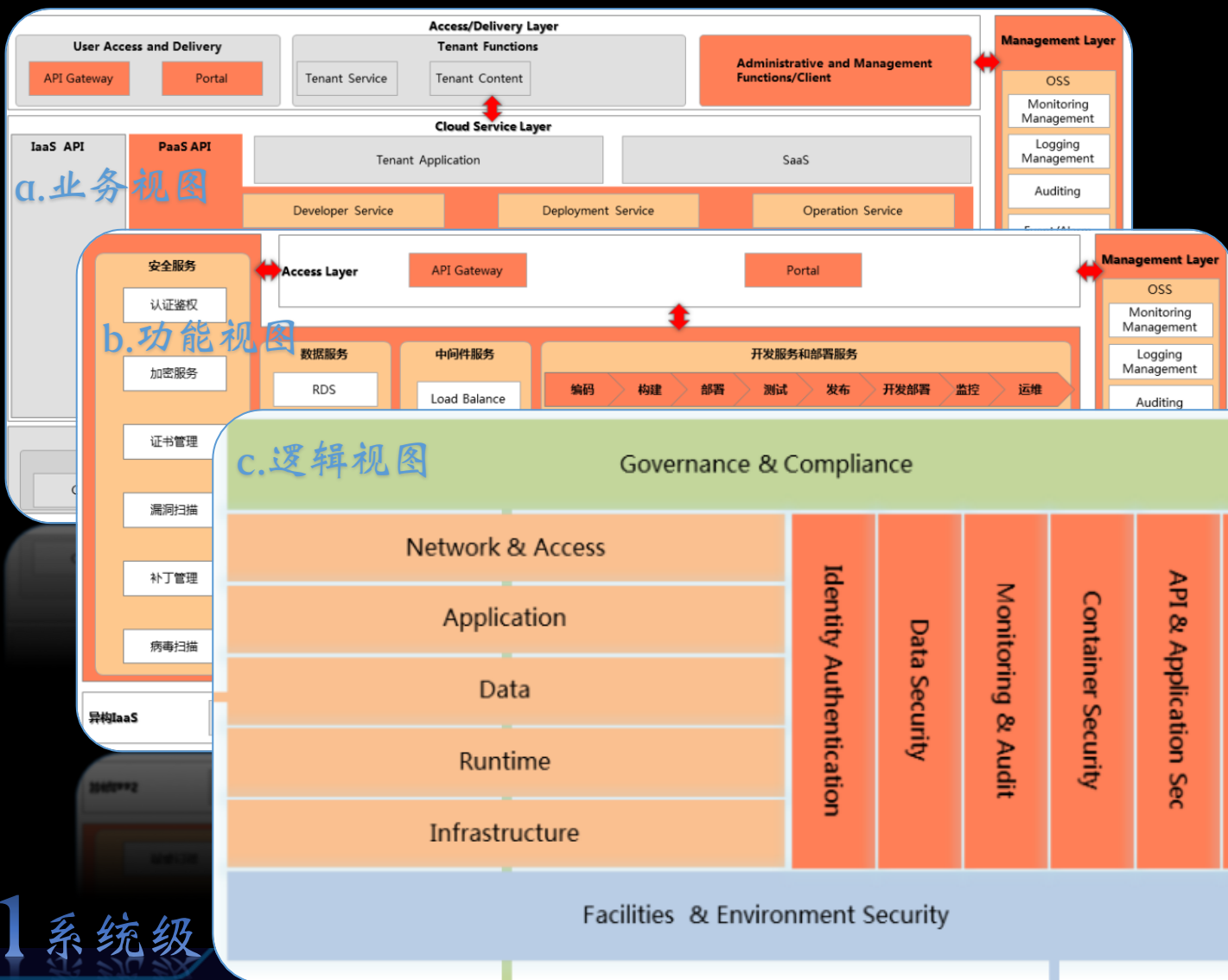
- 从层级架构(传统BS/SOA)到扁平/松散架构(API和微服务)
 - CI/CD自动化集成与交付
 - Infrastructure as Code与自动化运维
 - 节点爆发与策略坍塌
 - 分布式计算与新计算架构
 - 固有服务的云化适配性(共享资源隔离与多租户模型)
 - 集中式认证授权到分散式认证授权
 - 大量开源软件缺乏安全考虑
 - 云服务商能力的可靠性
-
- 云环境下的安全原则：一切皆不可信，纵深防御，动态防护，组件自治降低依赖

架构之困

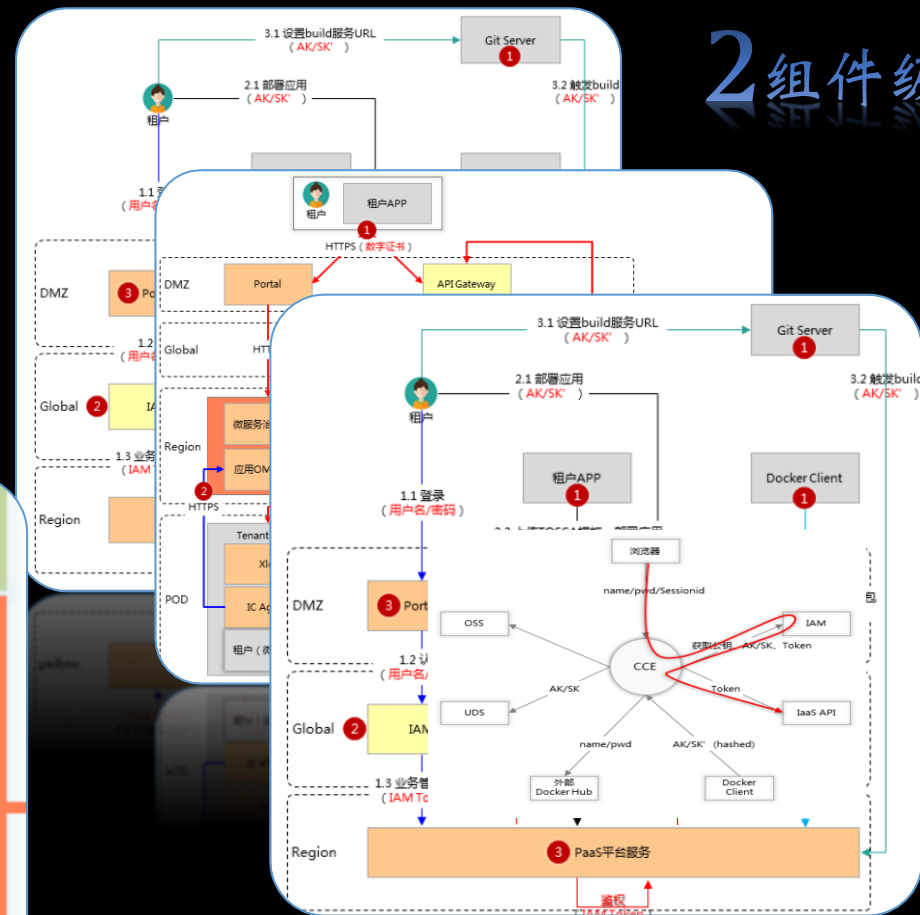
- 传统风险控制方法的失效
 - 基于资产的风险控制 → 基于服务的风险控制
 - 静态(长周期)防护思路 → 动态、自动化防护
 - 基于信任的防护 → 组件自防护
 - 边界防护 → 端点防护
 - 基于网络的访问控制 → 基于应用的综合访问控制
- 关键风险节点的转移
 - 运行环境与资源编排 (云管理、资源编排与调度节点风险)
 - 服务注册、发现与路由 (Service register, discovery and router)
 - 服务交付与访问 (API Gateway, Load Balancer, External FW, Anto-DDOS)
 - 共享数据和资源服务 (Object/File Storage, Cache, Message, Database, Bigdata)
- 核心风险控制要素
 - 云化服务资源隔离与访问控制
 - 租户空间隔离
 - 网间访问控制与隔离
 - 认证授权与审计
 - 数据安全与加密
 - 用户数据与隐私保护
 - 服务的可恢复性与容错设计

新环境下的安全原则：一切皆不可信，纵深防御，动态防护，组件自洽降低依赖

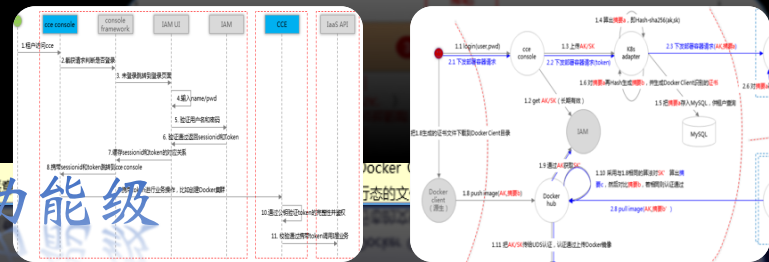
架构之行



2 组件级



3 功能级



1 系统级



饿了么安全应急响应中心
Eleme Security Response Center

THANKS



拉扎斯网络科技（上海）有限公司
Rajax Network & Tehnology Co

